

DLP Risk Assessment Framework

Identify and evaluate data loss risks — with scoring worksheets and a ready-to-fill risk register

Document ID	FRM-RA-001
Version	1.0 (template)
Classification	Internal
Owner	[Data Protection Officer / IT Security Manager]
Approved by	[Name, Title]
Effective date	[DD Month YYYY]
Next review	[DD Month YYYY — review at least annually]

Customization required

This template is a starting point published by the OpenDLP-LK community. Replace all bracketed placeholders, adapt the content to your organization's size, industry and risk profile, and obtain legal review before adoption. Aligned with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022.

<https://opendlp-lk.github.io> • Licensed under MIT — free to use, adapt and redistribute.

1. Purpose and Method

This framework guides [Organization Name] through a structured DLP risk assessment: identify data assets, enumerate threats, assess vulnerabilities, score risks on an impact × probability matrix, and select treatments. Repeat the assessment at least annually and after major changes (new systems, new data types, organizational restructuring, regulatory change).

2. Step 1 — Asset Identification

List every location where sensitive data lives. Use the inventory worksheet below (add rows as needed).

Asset ID	Asset / system	Data types held	Classification	Owner	Location
A-01	[HR database]	[Employee records, NIC, salaries]	[Restricted]	[HR Head]	[On-prem server]
A-02	[CRM / customer DB]	[Names, phones, NIC]	[Restricted]	[Sales Head]	[Cloud SaaS]
A-03	[File server]	[Contracts, financials]	[Confidential]	[Finance]	[On-prem]
A-04	[Email system]	[Mixed]	[Confidential]	[IT]	[Cloud]
A-05	[Laptops × N]	[Working documents]	[Mixed]	[IT]	[Endpoints]
A-06	[Backups / archives]	[Full copies of above]	[Restricted]	[IT]	[Offsite/cloud]

Checklist of locations commonly missed: cloud storage and SaaS applications, collaboration tools (Teams/Slack/Drive), email archives, mobile devices, backup and archive systems, test/development environments, third-party processors, printed records.

3. Step 2 — Threat Identification

Threat ID	Threat	Typical channel	Example
T-01	Insider — accidental	Email misdirection, wrong cloud share	Payroll file emailed to wrong supplier
T-02	Insider — malicious	USB, personal cloud, printing	Departing employee exfiltrates customer list
T-03	External cyberattack	Phishing, malware, exploited services	Credential phishing leading to mailbox exfiltration
T-04	Lost or stolen device	Laptop, phone, USB	Unencrypted laptop stolen from vehicle
T-05	Unauthorized cloud upload	Shadow IT SaaS	Staff use personal Drive for work files
T-06	Third-party breach	Vendor systems	Processor holding customer data is breached

T-07	Improper disposal	Paper, decommissioned drives	Un-shredded records; unwiped disks resold
------	-------------------	------------------------------	---

4. Step 3 — Vulnerability Assessment

For each asset–threat pair, evaluate the current controls. Mark each area Adequate / Partial / Missing:

- ☐ Encryption — data at rest encrypted on servers, endpoints, backups; TLS enforced in transit.
- ☐ Access control — RBAC in place; MFA on sensitive systems; quarterly entitlement reviews.
- ☐ Monitoring — DLP agents deployed; egress channels (email, web, USB, cloud) inspected; alerts triaged.
- ☐ Training — onboarding and annual refresher completion above [90%]; phishing simulation results acceptable.
- ☐ Device management — MDM coverage complete; unmanaged devices blocked from corporate data.
- ☐ Third parties — data processing agreements signed; vendor security assessed; breach clauses present.
- ☐ Disposal — shredding and certified media destruction procedures in use.

5. Step 4 — Risk Evaluation

Scoring scales

Score	Probability	Impact
1 — Low	Unlikely within 3 years	Minor: contained internally, negligible harm
2 — Medium	Could occur within 1–3 years	Serious: regulatory interest, harm to some data subjects, contract exposure
3 — High	Likely within 12 months / has happened before	Severe: notifiable breach, large-scale harm, penalties, major reputational damage

Risk matrix (Impact × Probability)

Impact !" / Probability !'	Low (1)	Medium (2)	High (3)
Critical / Severe (3)	Medium (3)	High (6)	Critical (9)
High / Serious (2)	Low (2)	Medium (4)	High (6)
Medium / Minor (1)	Low (1)	Low (2)	Medium (3)

Risk score = Impact × Probability. Treatment thresholds: 1–2 Low (accept with documentation), 3–4 Medium (treat within 6 months), 6 High (treat within 90 days), 9 Critical (treat immediately; escalate to senior management).

6. Step 5 — Risk Treatment

Strategy	When to use	Example
----------	-------------	---------

Avoid	Activity's risk outweighs its value	Stop collecting NIC numbers where a customer ID suffices
Reduce	Controls can cut likelihood or impact	Deploy endpoint DLP blocking USB writes of Restricted data
Transfer	Residual financial risk is insurable / contractible	Cyber insurance; indemnity clauses with processors
Accept	Residual risk is Low and treatment is disproportionate	Documented acceptance of Internal-data print risk, signed by owner

7. Risk Register (worksheet)

Risk ID	Asset	Threat	P (1-3)	I (1-3)	Score	Level	Treatment	Owner	Due
R-01	[A-02]	[T-01]	[3]	[3]	[9]	[Critical]	[Reduce: DLP email rule]	[IT Sec]	[date]
R-02									
R-03									
R-04									
R-05									
R-06									
R-07									
R-08									

Review cadence

Review Critical and High risks monthly until treated; review the full register quarterly. Re-run the complete assessment annually and record it as PDPA accountability evidence.

8. Sign-off

Assessment performed by:

Date of assessment:

Reviewed by (DPO):

Approved by (management):

Next assessment due:
